



云环境下的主机安全

Host security in cloud environment

演讲人：李科

职务：椒图科技常务副总裁

邮箱：Ke.li@jowto.com

日期：2014-09-24



中国互联网安全大会



360互联网安全中心

China Internet Security Conference 2014

2014中国互联网安全大会

椒图科技是国内著名信息安全解决方案提供商，是深圳/北京市高新技术企业，在服务器操作系统加固领域探索实践长达十余载，拥有业内顶尖的服务器安全研究团队。核心人员早在2004年参与从事安全技术的研究和国家信息安全等级保护相关标准的起草工作。



椒图科技

Jowto Technology Co., LTD

领先的信息安全解决方案提供商

Leading information technology
and security solution provider



目录



1

云计算构架

2

云环境的安全风险

3

实例分析

4

云环境下的主机安全

5

方案及案例

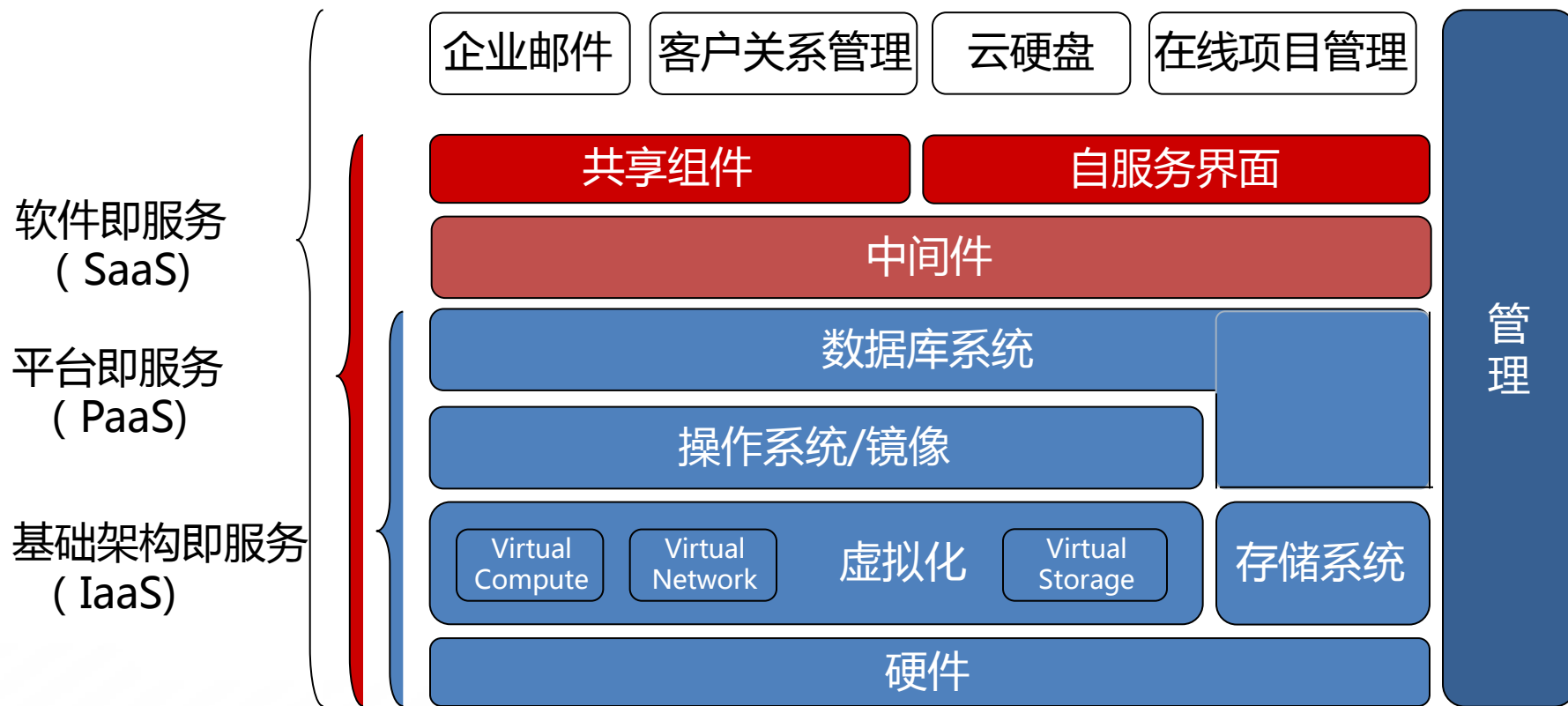


云计算构架

什么是云



云 “积木”



什么是云



- IaaS (Infrastructure as a service)
 - 服务器虚拟化 (Server Virtualization)



- 公有云 (public/external)
- 私有云 (private/internal)

什么是云

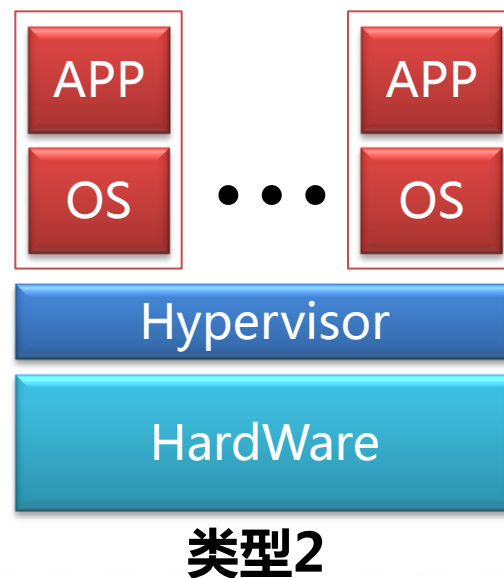
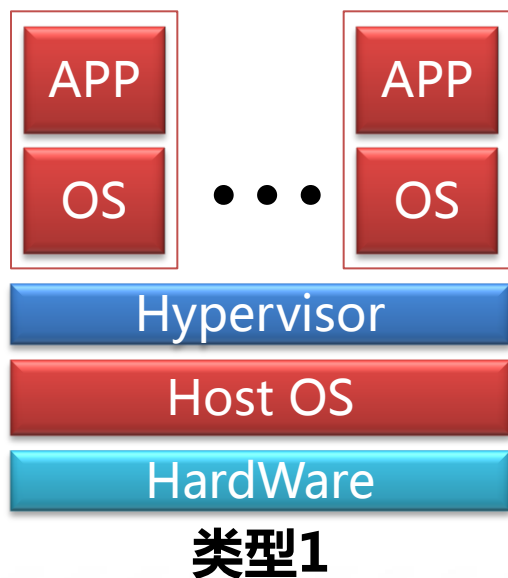


- 云计算 (Cloud Computing)
 - 一种商业模式 (Business Model)
 - 云计算是一种资源交付和使用模式，指通过网络以便利的、按需付费的、易扩展的方式获得高可用性的所需资源(硬件、平台、软件)。

云的支撑技术



- 虚拟化
 - Hosted（类型1）
 - Bare Metal（类型2）



云计算对国家的意义



- 全国政协常委赖明建议：
“尽快将大数据等现代技术的运用上升为国家战略，制定专项发展规划，引导大数据技术和产业快速发展，以提升政府治理能力现代化。云计算是大数据的基础，期待在云计算、大数据运用下，我国的综合国力能更上新台阶！”



中央网络安全和信息化小组的成立



- 战略清晰、技术领先、产业先进、攻防兼备
 - 2014年2月27日，中央网络安全和信息化领导小组成立。习近平任组长，李克强、刘云山任副组长。
 - “没有网络安全就没有国家安全，网络和信息安全牵扯到国家和社会稳定，是我们面临的新的综合性挑战”



云环境的安全风险

云的安全隐患



- 云计算不是一项新技术，从本质上讲传统的黑客技术依旧可以对云服务进行攻击。

数据高度集中为
黑客获取更多数据
带来便利

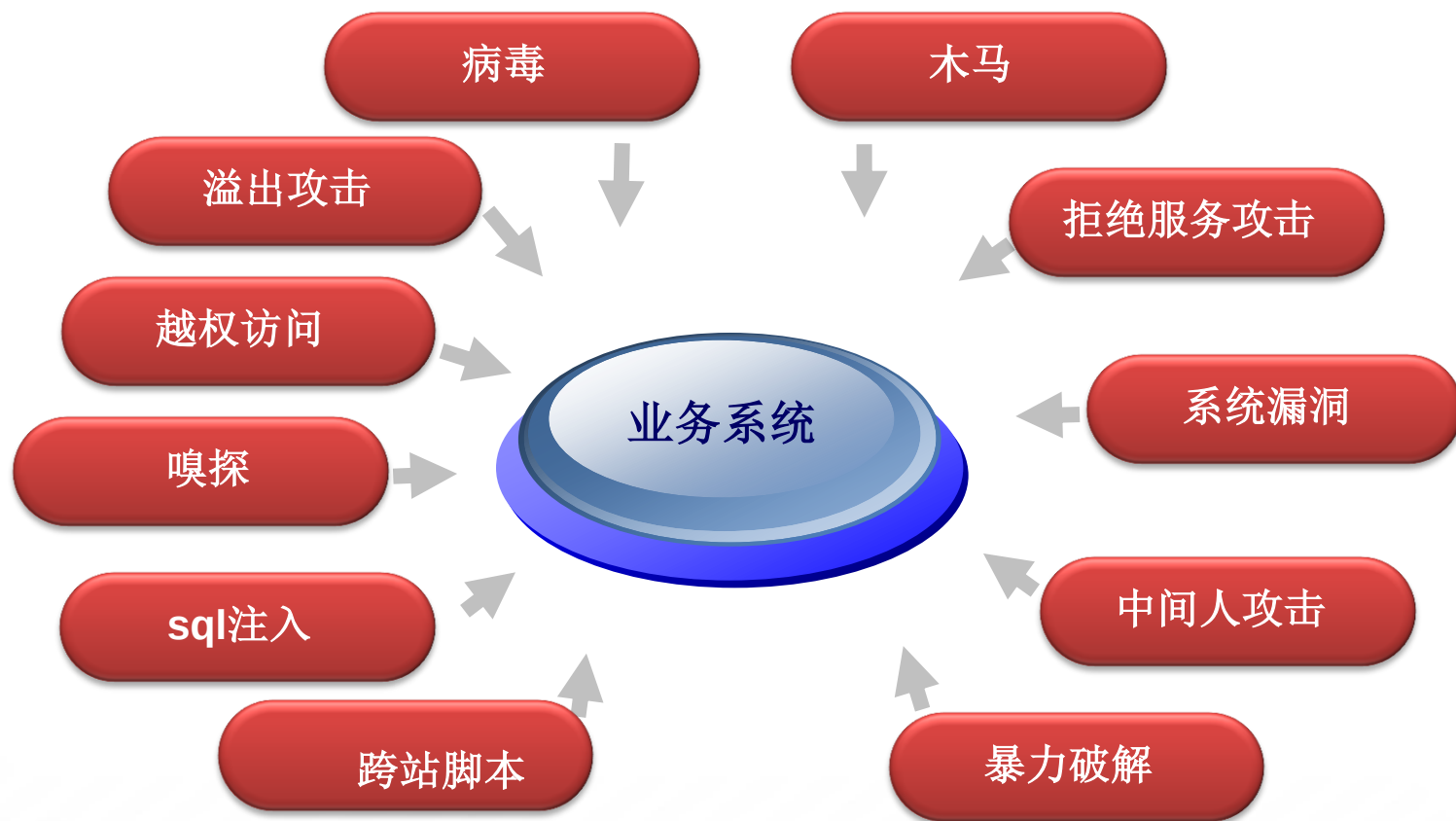
附带黑客攻击

多客户端访问
增加数据截获风险

复杂的应用环境
使安全风险增加



传统形态的威胁



云环境特有的安全风险



- 一、hypervisor拒绝服务
- 二、Guest os嗅探其他主机
- 三、Guest os逃逸至Host os
- 四、Guest os逃逸至hypervisor
- Others



实例分析

一、hypervisor拒绝服务

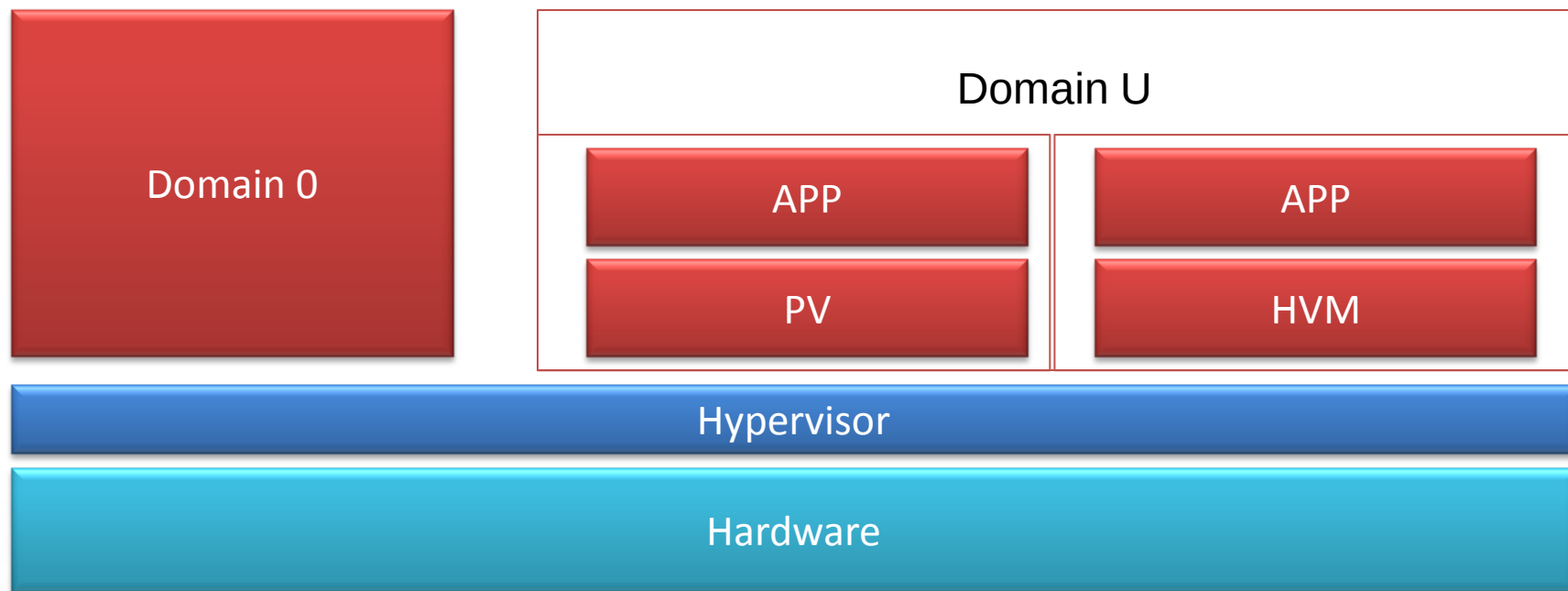


- CVE-2012-2625漏洞实例
- 本地构造畸形内核镜像，XEN导入时会崩溃，影响hypervisor的正常运行，使其无法提供正常服务。

XEN的结构



- XEN是剑桥大学开发的一个开源虚拟机监视器
- Domain 0用于管理Domain U虚拟机
- PV为半虚拟模式
- HVM为全虚拟模式



攻击过程回放



一次性加载

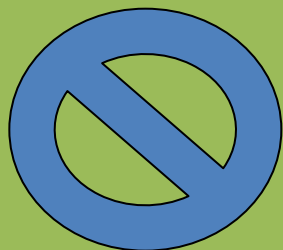
pygrub

1G大小时

Vmlinuz
内核文件

8G
大小
时

内存空间
8G



拒绝服务

Domain U

APP

APP

PV

HVM

Hypervisor

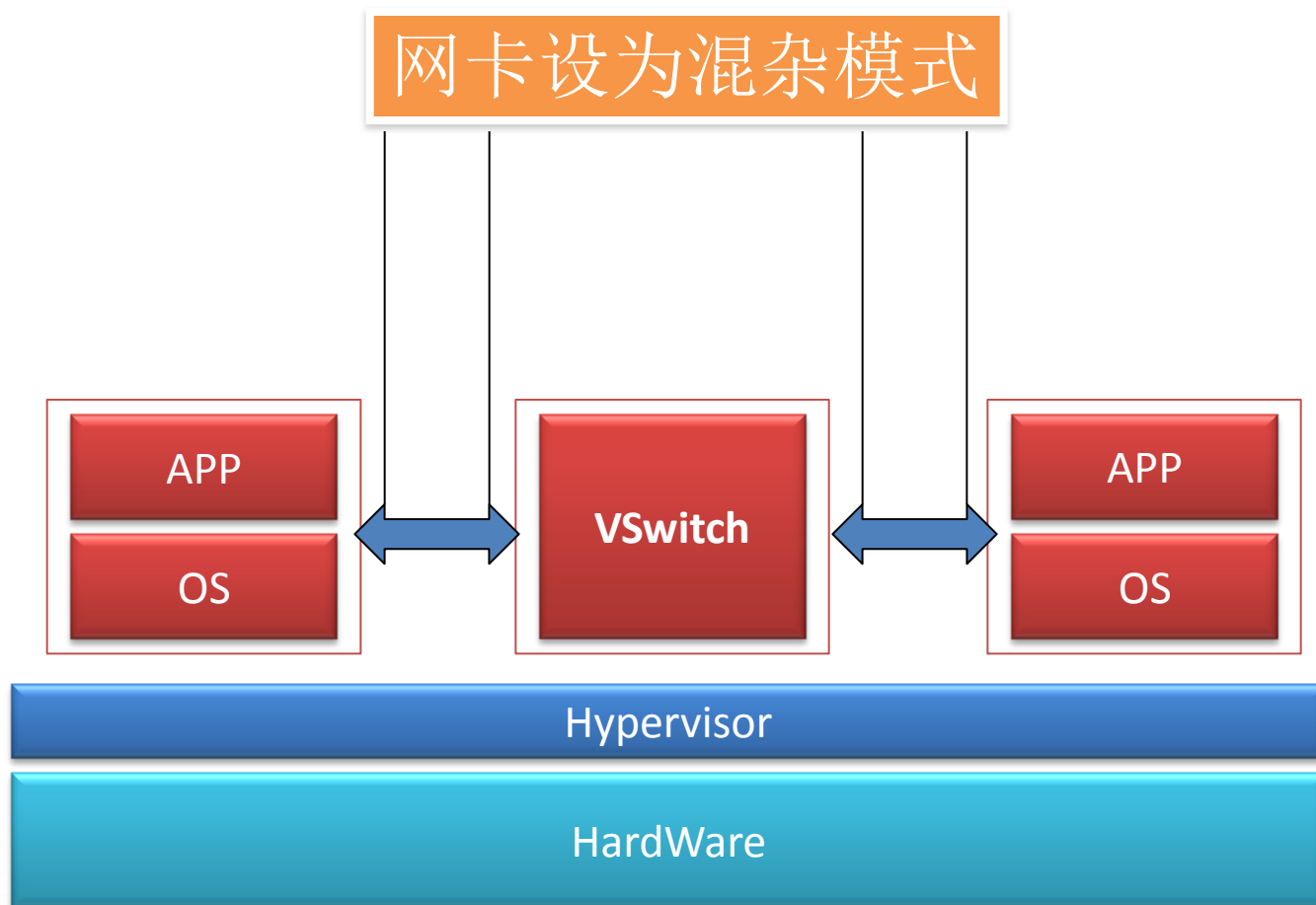
Hardware

CVE-2012-2625

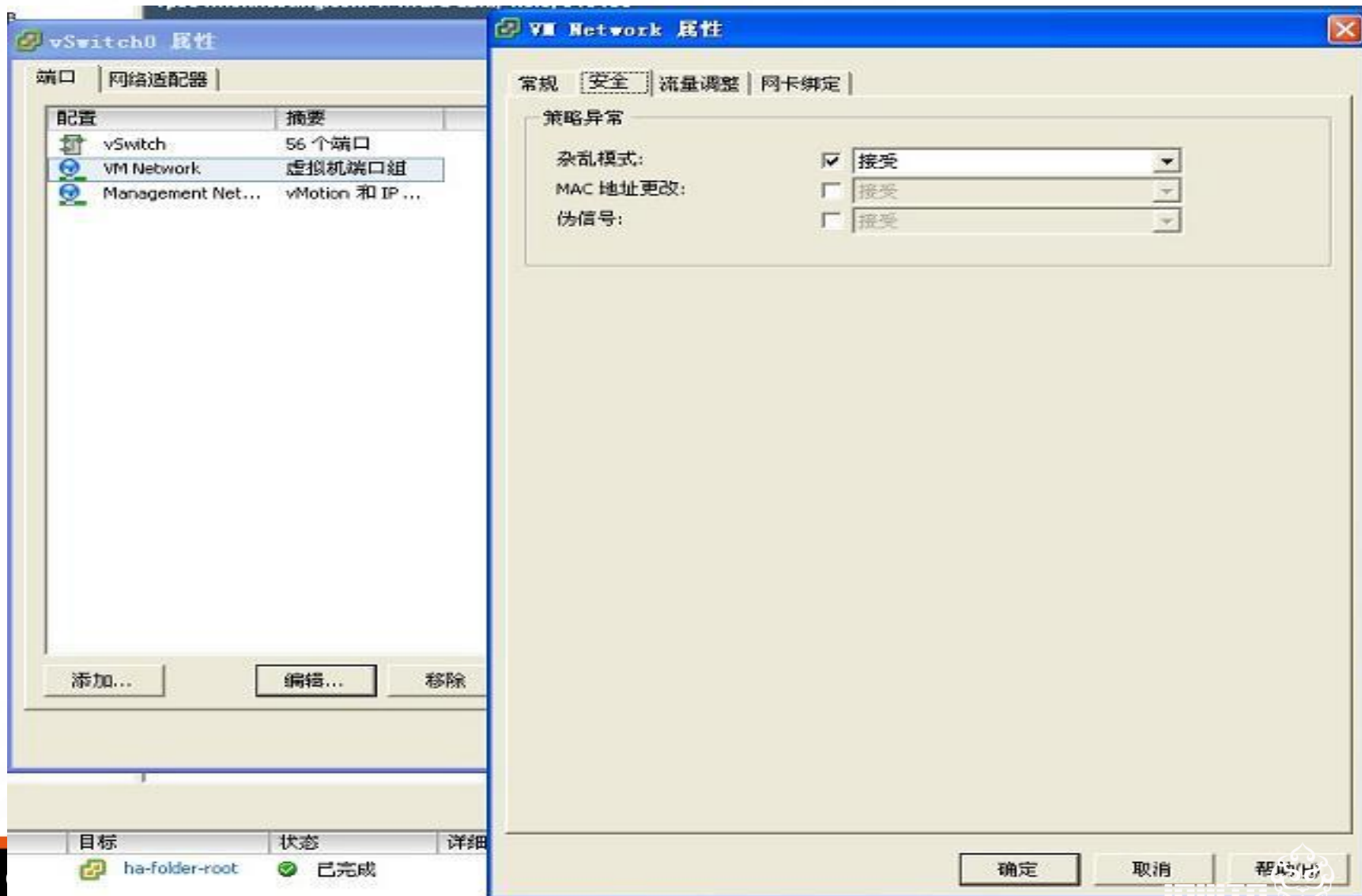


- 发布日期：2012-05-04 更新日期：2012-05-30
- 受影响系统：RedHat Fedora 17 XenSource Xen 4.1.2
- 参考资料：基于模糊测试的虚拟机安全漏洞挖掘工具的设计与实现
- <http://www.doc88.com/p-0611913713596.html>

二、Ghost OS嗅探其他主机



二、Guest OS嗅探其他主机



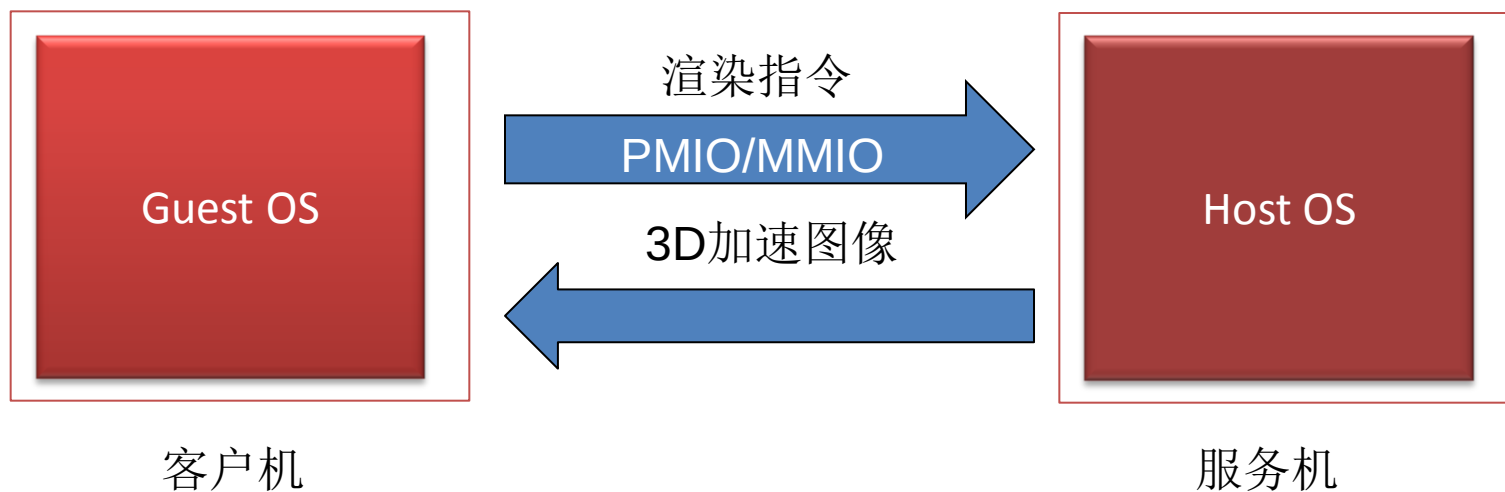
三、Guest os逃逸至host os



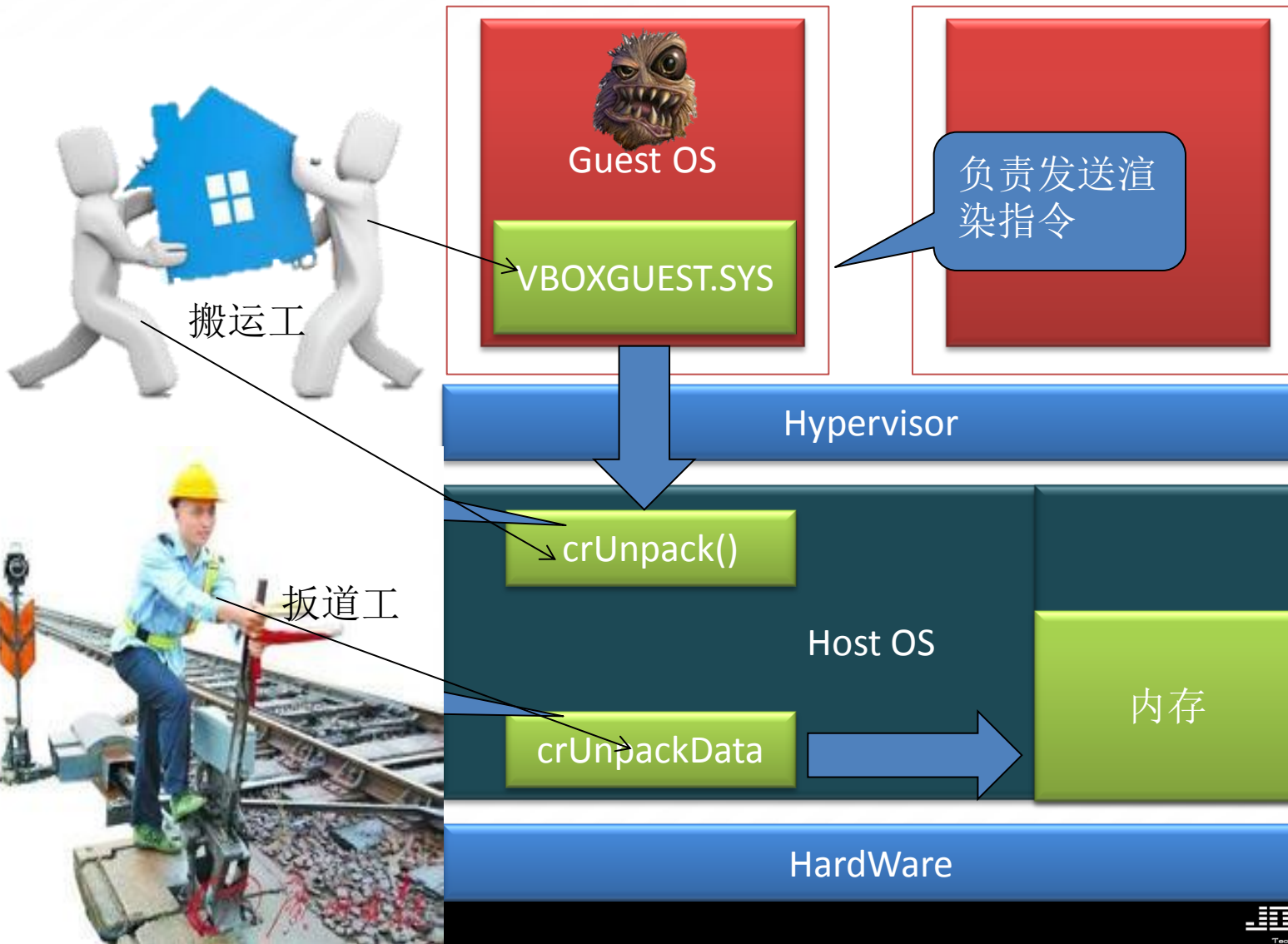
- CVE-2014-0983漏洞实例

- Oracle VM VirtualBox是一款开源虚拟机软件。
- Oracle VM VirtualBox
'crServerDispatchVertexAttrib4NubAR()' 函数不正确处理用户提交的参数，允许攻击者利用漏洞破坏任意内存地址，可使系统崩溃或提升权限。

OpenGL共享服务



攻击过程回放



CVE-2014-0983



- 漏洞发布时间:2014-03-11 漏洞更新时间:2014-03-12 影响系统
Oracle VirtualBox v4.2.20 Oracle VirtualBox v4.3.6
- 参考资料：虚拟机的威胁_VirtualBox逃逸技术
- <http://www.91ri.org/10371.html>

四、Guest os渗透hypervisor



■ CVE ID: CVE-2011-1898

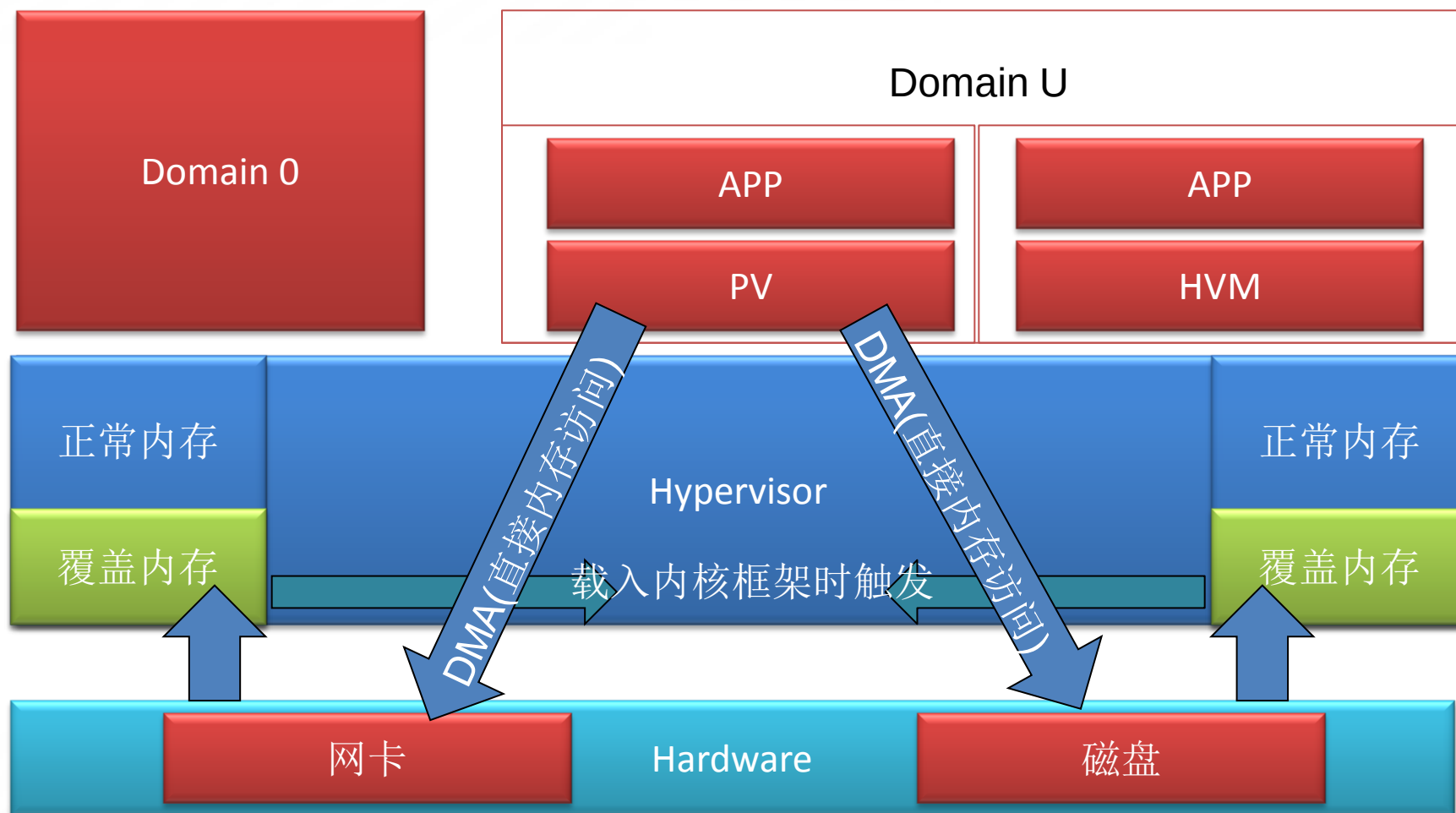
- Xen在实现上存在通过MSI注入陷阱漏洞，远程攻击者可利用此漏洞注入陷阱并控制主机。
- 没有设置中断重映射的Intel VT-d芯片组没有阻止使用PCI设备客户机使用DMA写入中断注入寄存器来产生MSI中断。
- Xen未对DMA传输未做限制。因此具备DMA能力的设备可以覆盖和写入到系统的任意内存地址，即使是xen的内存空间。

DMA的特性



- DMA(Direct Memory Access , 直接内存访问) 是所有现代电脑的重要特色，它允许不同速度的硬件装置来沟通，而不需要依赖于 CPU 的大量中断负载。否则，CPU 需要从来源把每一片段的资料复制到暂存器，然后把它们再次写回到新的地方。在这个时间中，CPU 对于其他的工作来说就无法使用。

攻击过程回放



回环Loopback模式

CVE-2011-1898



- 漏洞发布时间:2011-06-30 漏洞更新时间:2011-06-30
- 影响系统 XenSource Xen Red Hat Fedora 15 Red Hat Fedora 14 Qumranet KVM
- 参考资料: 渗透Xen hypervisor
- <http://blog.csdn.net/q123456789098/article/details/7832121>



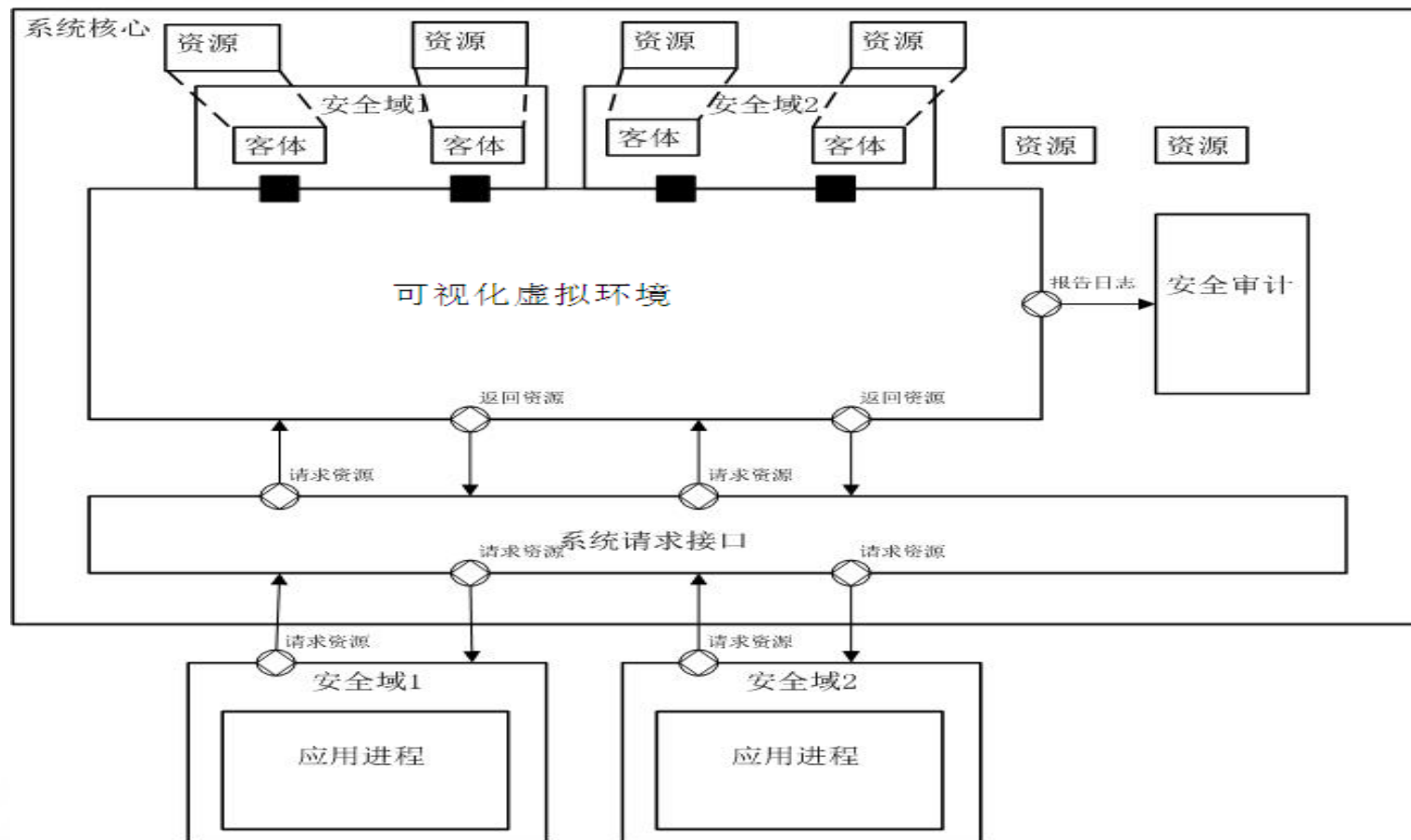
云环境下的主机安全

主机安全的意义

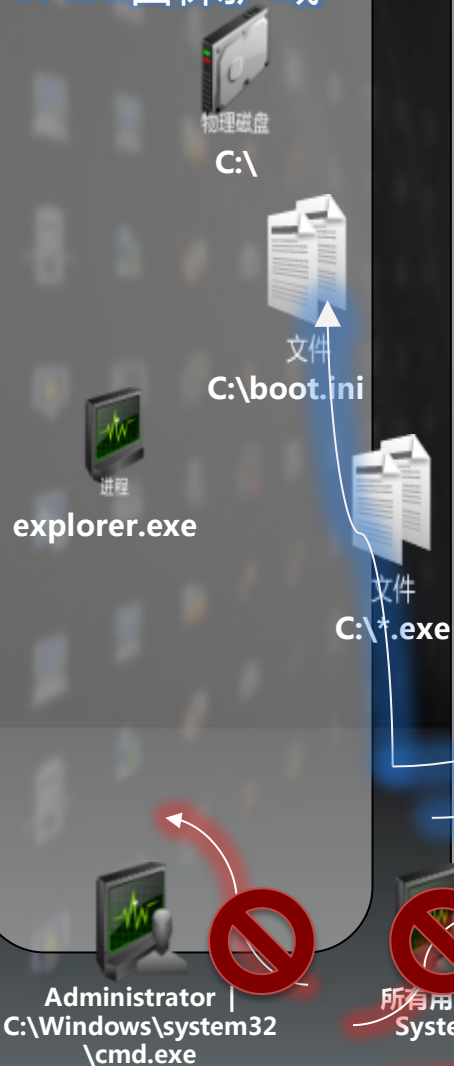


- 我们看到，以上的逃逸实例中的路径， guest os 是作为发源地，无论是逃逸到host还是逃逸到hypervisor,甚至通过hypervisor最后再通过hypervisor控制其他vm，都跟主机是息息相关，那么我们的防范思路就从主机上展开。
 - 虽然老漏洞已经补上，但是能够实现逃逸的本质并没有变化，新漏洞同样会利用这些原理。
-
- 对策一、针对os环境，进行安全域的划分
 - 对策二、针对不同的安全域进行强制访问控制
 - 对策三、针对guest os和host os均部署主机安全防护策略。

在操作系统上划分虚拟安全域原理



JHSE自保护域



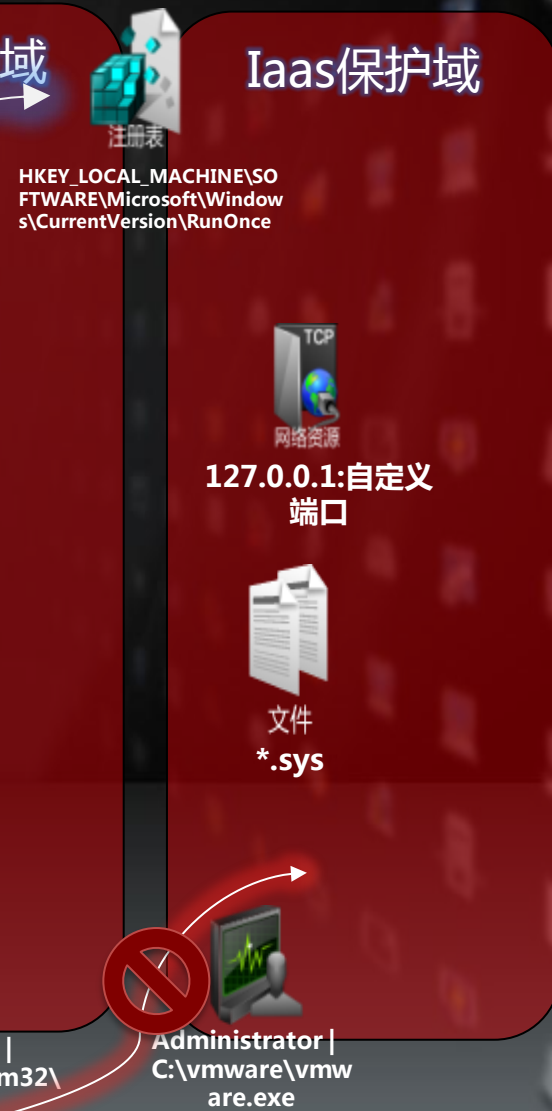
系统保护域



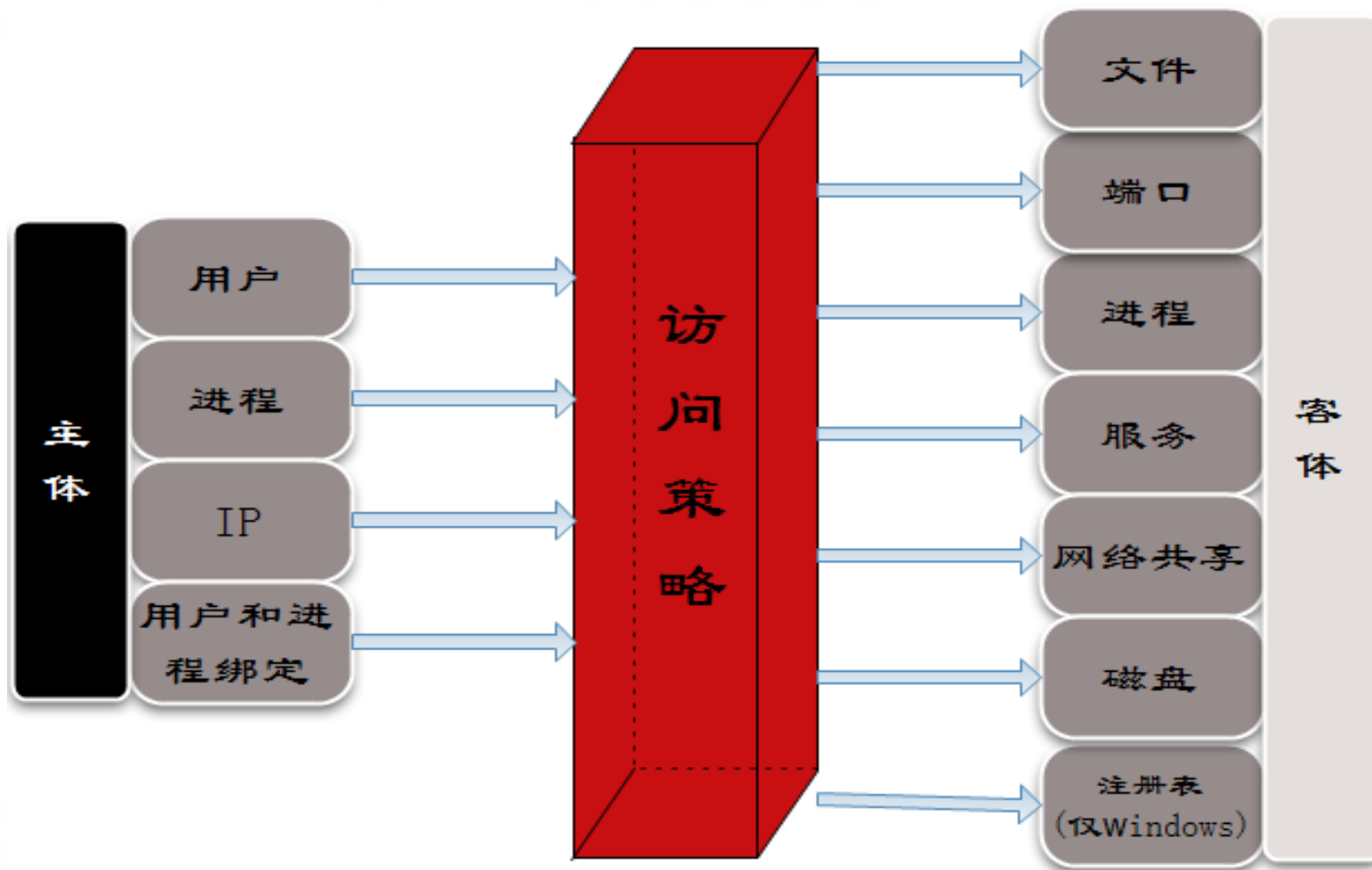
业务保护域



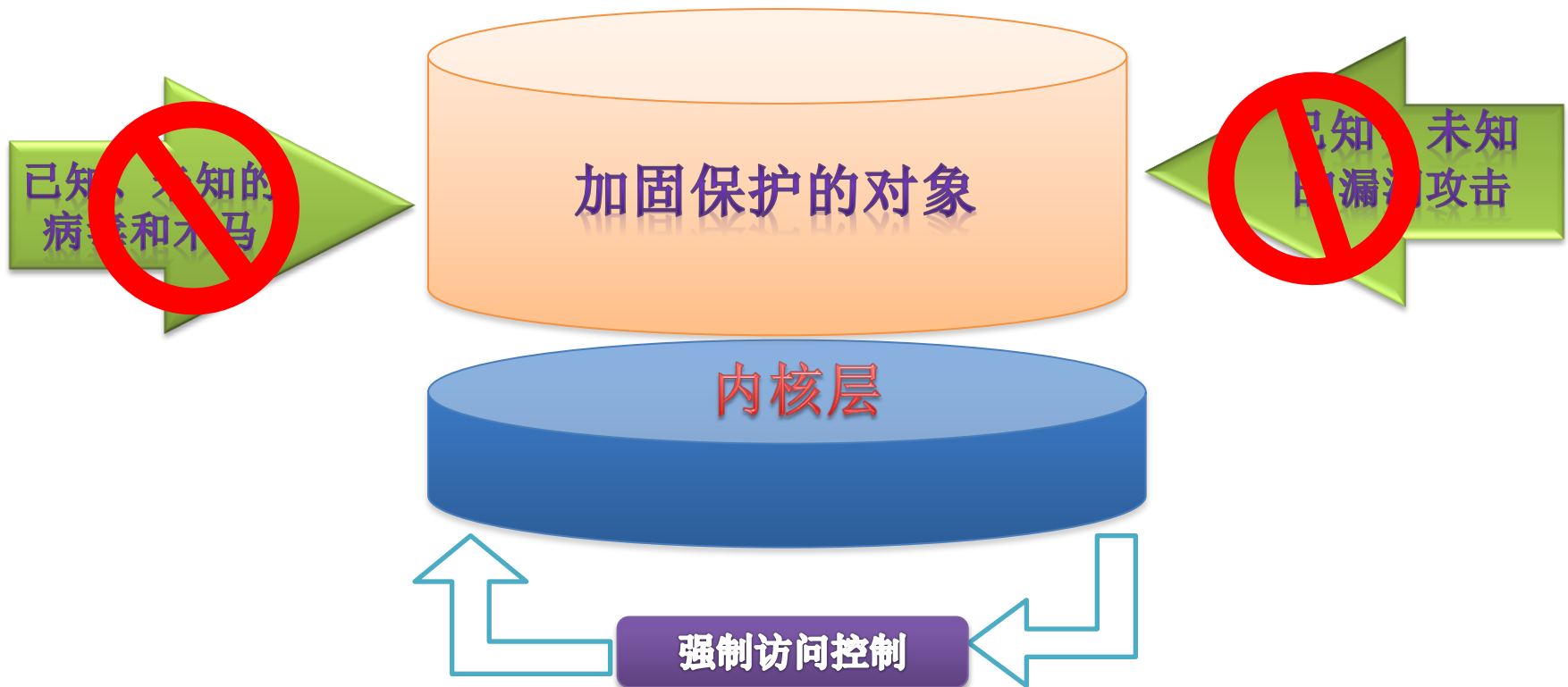
Iaas保护域



域内实施强制访问控制策略



强制访问控制实现原理



实现对操作系统层攻击主动防御、预警、实时防护

针对逃逸部署防护策略

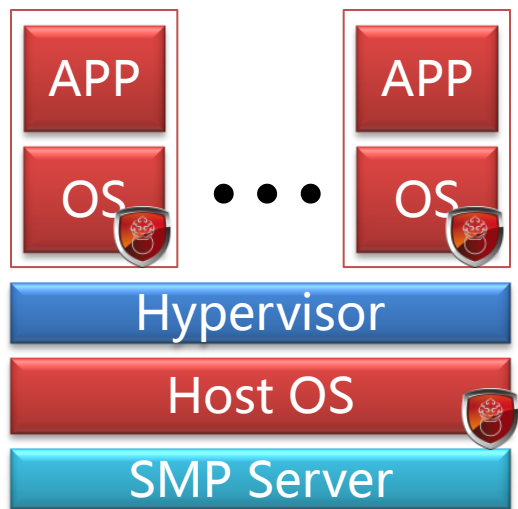


■ 访问控制策略描述：

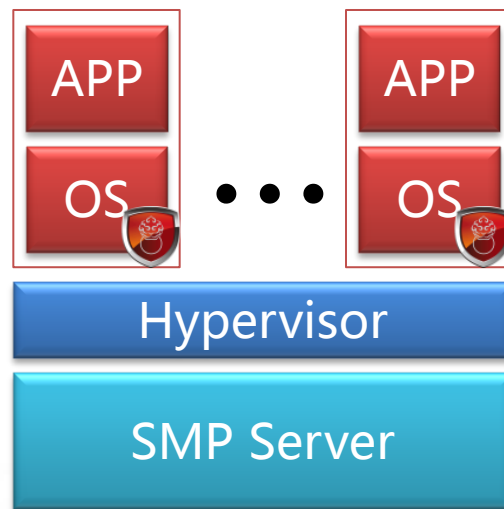
- Guest os :
- 主体：虚拟机相关进程。
- 客体：虚拟机配置文件、相关驱动。
- 只允许虚拟机进程访问客体、其他进程无权限访问。

Host os :

- 主体：虚拟机相关进程。
- 客体：虚拟机配置文件、虚拟机镜像文件、相关驱动。
- 只允许虚拟机进程访问客体、其他进程无权限访问。
- 虚拟机进程不允许创建其他进程。



类型1



类型2



方案及案例

JHSE安全云解决方案



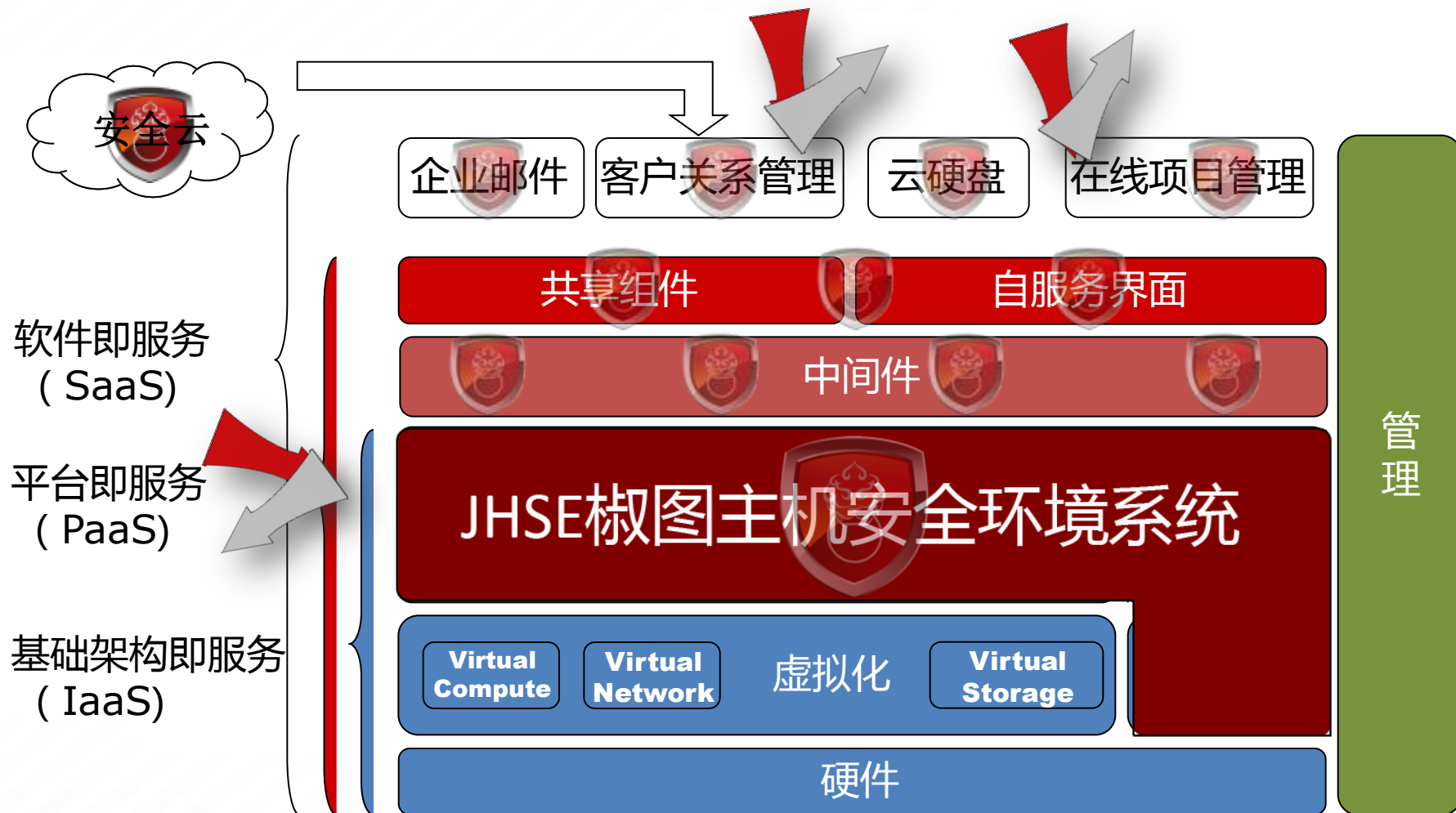
■可信改造现有操作系统

■不影响现有系统的上层应用

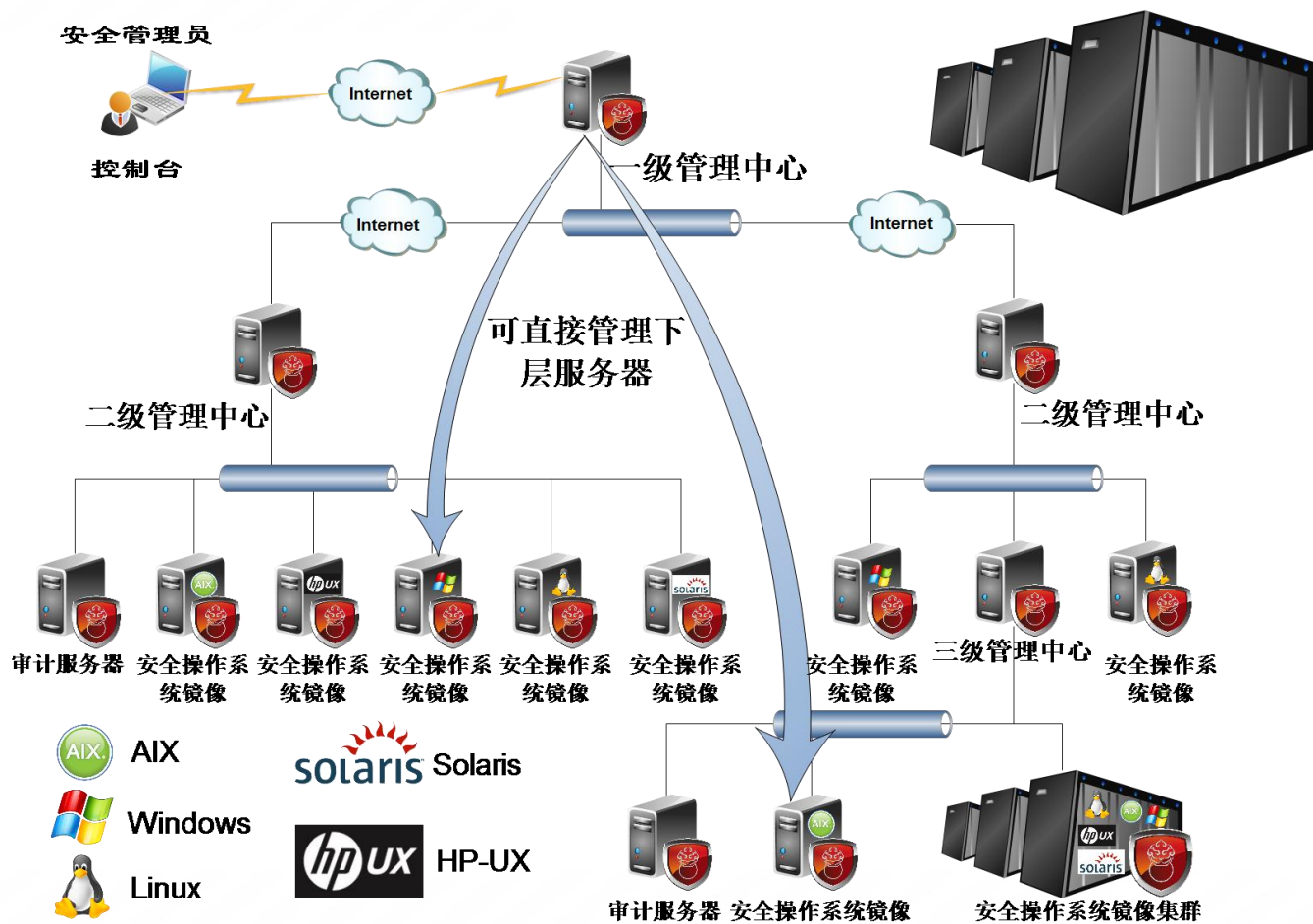
JHSE安全云解决方案



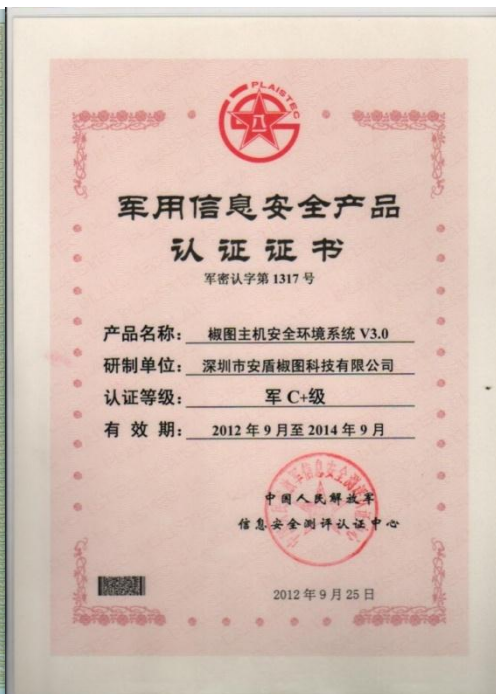
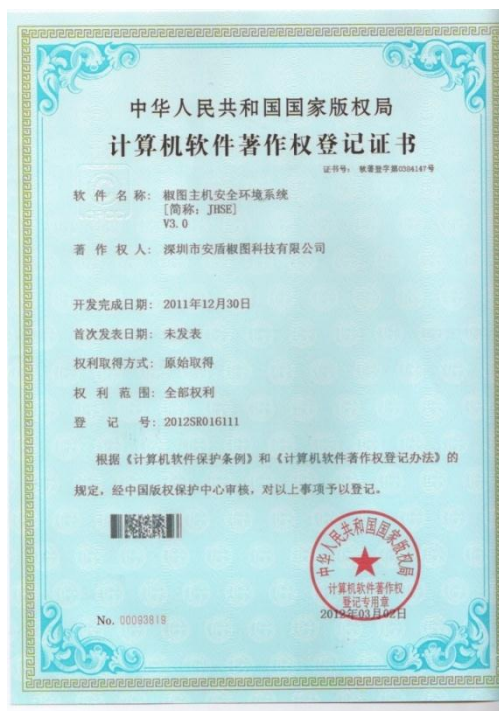
操作系统与安全云



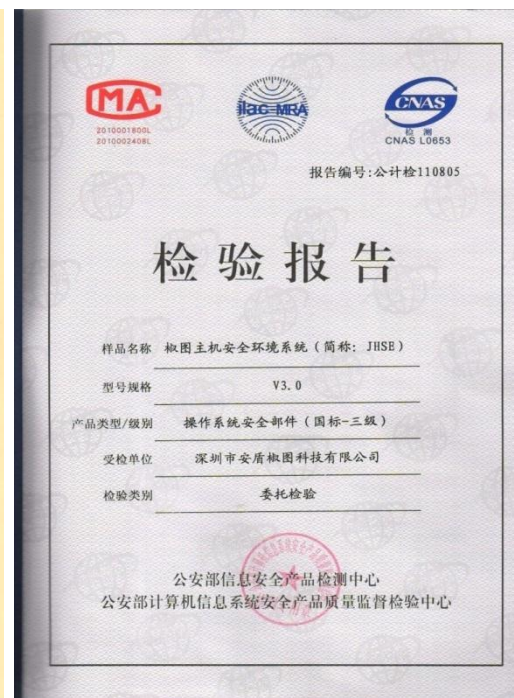
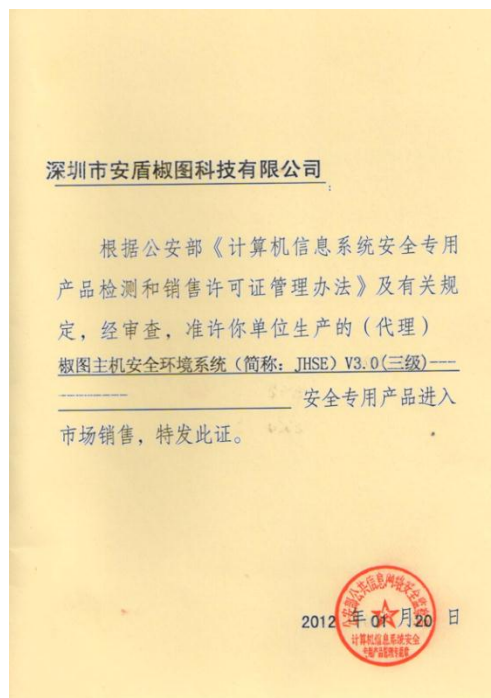
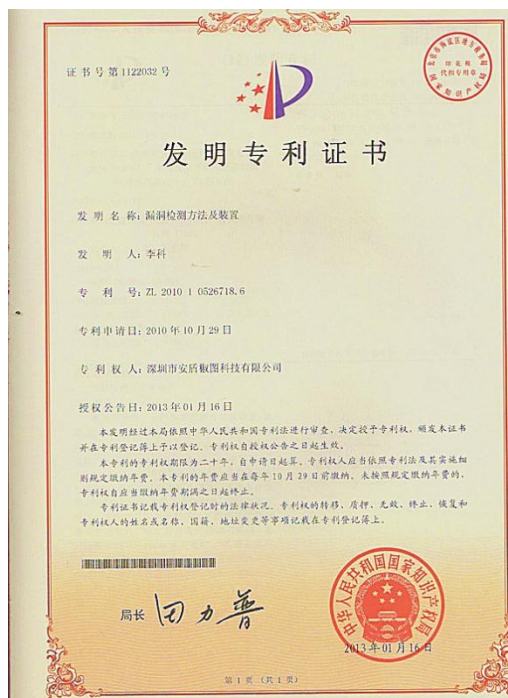
JHSE在云中的部署



产品资质



产品资质



团队项目



团队项目



团队项目



- 2005年参与国家标准《信息安全技术 信息系统安全等级保护基本要求》（ GB/T22239-2008 ）、《信息安全技术 服务器安全技术要求》（ GB/T21028-2007 ） 的起草工作。
- 2008年承担了第29届奥运会、2010年第41届世博会的信息安全保障工作。
- 2012年北京市 “十八大” 网络安全应急处置队伍成员单位
- 北京市等保地方标准起草承担单位
- 中国联通总部信息安全检查标准起草工作
- 国家网络与信息安全信息通报机制 “技术支持单位”

椒图科技安全方案及成功案例





中国互联网安全大会





迄今为止，最好用的服务器安全软件

简单、可靠、免费



领先的信息安全解决方案提供商

Leading information technology
and security solution provider

跨平台支持Windows/linux，独创linux远程图形界面管理功能

- ✓ 基于系统内核加固技术，保护超过100多项操作系统安全薄弱点
- ✓ 智能识别百万级病毒、木马、后门、webshell等安全威胁
- ✓ PC端远程管理、监控服务器，时时掌控服务器状态
- ✓ 采用C/S架构，占用服务器资源更少、效率更高
- ✓ 独创web沙箱功能，将web服务隔离在受限环境，有效抵御APT等高级攻击方式
- ✓ 独创网站后台防护功能，智能隐藏网站后台URL地址，让黑客无迹可寻
- ✓ 最强抗CC能力，将热点追踪、代理溯源等能别识别技术与驱动级防护技术相结合，CC攻击识别率高达99.9%

2013椒图科技安全公测



主办单位：椒图科技 协办单位：硅谷动力
测试时间： 2013年3月25日-4月8日

12300人次广泛参与；

历时**15天**攻防对决；

公布**ip、root和密码**，修改指定文件奖金**30000**

把产品放在“**最危险**”的地方做“**最真实**”的测试

JHSE产品的强壮型、安全性得到全面验证！

受**JHSE**防护的**AIX服务器**

最终**无人攻破**

全球有奖公测活动得到**各方关注**，最终**完美收官！**

2014椒图科技攻防游戏 一层F1展区右侧



- 活动主题：

参加椒图科技攻防游戏，**10万**大奖等你拿

- 面向人群：参与安全大会的计算机技术爱好者

- 环境：受保护的服务器

- 游戏规则：

1，参加游戏即可获得精美礼品一份

2，成功获取受保护的服务器中的JOWTO文件，并对其内容修改的参赛者即可获得1000元现金奖励

3，我们会记录成功者所用时间，截止2014.9.25下午3点，用时最少的成功者将获得10万奖金！



Thanks!

椒图科技 北京分公司

地址：海淀区中关村东升科技园北领地B-2号楼6层C601室

邮编：100020

总机：010-65014696

传真：010-65016411

网址：www.jowto.com

椒图科技 深圳总公司

地址：南山区科技南十二路康佳研发大厦601室

邮编：518057

总机：0755-86638038

传真：0755-86638028

网址：www.jowto.com

